ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Studio 5000 Logix Designer (Logix controller programming) · Component type: **Software Application (SAR) - PLC/PAC engineering software** · Target SL = SL 3

Where to work	**Studio 5000 Logix Designer** + **FactoryTalk Security** (auth/RBAC - via FactoryTalk Admin Console; see the FactoryTalk sheet). Project controls: **Tools › Security › Configure Source Protection** (routine/AOI); **Controller Properties › Security tab** (Security Authority binding + Change Detection). Comms via **FactoryTalk Linx** (CIP / CIP Security). Audit/versioning via **FactoryTalk AssetCentre**.
Ports / paths	Controller comms = EtherNet/IP **CIP TCP 44818 / UDP 2222** (+ CIP Security TLS/DTLS); FactoryTalk Directory **RPC/DCOM 135+dynamic**; FactoryTalk Activation **27000/1443**. Project file = **.ACD** (protect via Source Protection + Security Authority binding). Firmware via ControlFLASH Plus / PCDC.
Notes	SAR - Rockwell Studio 5000 Logix Designer (Logix controller programming). User authentication/RBAC is provided by **FactoryTalk Security** - assess that on the FactoryTalk sheet; here focus on project protection, controller-download authorization, and software integrity. Confirm the Studio 5000 version and that it is patched (Rockwell PSIRT).
How to read	Each row = native step-by-step (Studio 5000 / FactoryTalk / controller) + command-level external-tool steps. Default read-only (open the .ACD read-only, review Security tab/Source Protection). Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - pull BOTH the .ACD and the .L5X

Do this BEFORE working the checklist - you need BOTH files, not just the ACD upload. Going through the config screens and the logic screens requires the exported **.L5X** in addition to the native **.ACD**:
1. Upload the RUNNING program first. In Studio 5000 Logix Designer set the comms path in FactoryTalk Linx / RSLinx (**Who Active**), go **online** with the controller and **Upload** - the copy on disk may be stale versus what is actually executing. Record the controller catalog, **firmware revision**, slot, and the FactoryTalk user who may upload/download.
2. Save the .ACD (File › Save / Save As). This is the authoritative, version-matched project - needed to go back online and to see everything natively (rung/tag descriptions, AOI source, faceplates). It is **locked to the Studio 5000 major version** and is **not** human-readable or diffable.
3. ALSO export the .L5X (File › Save As → Save as type: **Logix Designer XML File (*.L5X)**, full project). The L5X is **version-independent XML** you can open, search and **diff** without the exact Studio 5000 build - this is what you actually walk for the **config screens** (Controller Properties, Module/I-O tree, Tasks/Programs, comms, controller security) and the **logic screens** (routines - ladder/FBD/ST, Add-On Instructions, tags). Grabbing only the ACD is how reviews get stuck.
4. Grab the supporting evidence too: tag + documentation export (Tools/Tags → Export to **.CSV**), the I-O module tree, Controller Properties screenshots, and on **GuardLogix** the **Safety Signature** (ID + date). Note the FactoryTalk Security roles for attribution - the controller log alone lacks user identity.
5. Name + protect the files (keep BOTH). `<site>_<zone>_<assetTag>_<catalog>_slot<n>_fw<rev>_<YYYYMMDD-HHMM>_<initials>` with the matching **.ACD** and **.L5X** extensions (and the .CSV tag export). SHA-256 hash each; store **only** on the encrypted evidence share; follow the project retention/classification policy; never email in cleartext. **Why both:** the ACD is authoritative but unusable without the matching Studio 5000 version and cannot be diffed; the L5X is the portable, reviewable, diffable record you build the checklist findings from.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm engineering access authenticates via **FactoryTalk Security**: opening/editing/downloading the project requires a FactoryTalk logon (Network Directory). Bind the project to a **Security Authority** (Controller Properties › Security › Security Authority) so only users of that FactoryTalk Directory can open/download it. **Test:** open the .ACD / attempt a download without a FactoryTalk logon -> denied. **Ext. tools:** FactoryTalk Admin Console (users/secured actions); Studio 5000 (Security tab - Security Authority set).	FactoryTalk logon required; project bound to a Security Authority; no anonymous program access.	
SR/CR 1.2	Software process / device identification	Confirm the target controller identity (catalog, IP, serial) and that FactoryTalk Linx paths are defined; where CIP Security is used, the controller is bound by certificate. **Ext. tools:** Studio 5000 (Who Active / path); `nmap -sU -p 44818 --script enip-info <plc>`; FactoryTalk Policy Manager.	Controller identity confirmed; comms bound (CIP Security where used).	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.3	Account management	Accounts are managed in **FactoryTalk Security** (named users/groups, least privilege, no shared logins) - verify there. In Studio 5000 confirm no local bypass (e.g. projects not left unsecured / Source Protection keys not shared). **Ext. tools:** FactoryTalk Admin Console (users/groups); Source-Protection key custody review.	Accounts managed in FactoryTalk (least privilege); no shared keys/bypass.	
SR/CR 1.4	Identifier management	Confirm unique FactoryTalk user identifiers and a unique controller identity (name/IP/serial); no reuse. **Ext. tools:** FactoryTalk Admin Console; Studio 5000 controller properties; inventory.	Unique user and controller identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Password strength is enforced by the **FactoryTalk Security Policy** (see the FactoryTalk sheet). For **Source Protection**, use strong source keys (min 4 chars is the tool floor - use much stronger) or License-based Source Protection; store keys in the vault. **Ext. tools:** FactoryTalk (password policy); Studio 5000 (Source Protection key strength).	FactoryTalk password policy enforced; strong Source-Protection keys; defaults changed.	
SR 1.6	Wireless access management	**N/A.** Engineering software with no wireless interface. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	Where **CIP Security** secures the controller link, confirm CA-signed device/engineering certificates (FactoryTalk System Services / enterprise PKI), valid, strong keys; defaults replaced. **Ext. tools:** FactoryTalk Policy Manager (cert status); openssl (if TLS web).	CA-signed certs for CIP Security; strong keys; defaults replaced.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the FactoryTalk logon and Source-Protection password prompts mask entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Login lockout is enforced by the **FactoryTalk Security Policy** (account lockout) - verify it is enabled (see the FactoryTalk sheet). Source-Protection has no lockout; rely on key secrecy + host control. **Ext. tools:** FactoryTalk (lockout policy); note Source-Protection residual.	FactoryTalk lockout enabled; Source-Protection residual noted.	Delegated.
SR/CR 1.12	System use notification	No Studio 5000 banner; enforce the approved use notice on the engineering-workstation host (GPO). **Ext. tools:** Host `gpresult /h gp.html`.	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the engineering workstation + controller are in the trusted OT zone; remote engineering via VPN/jump host + MFA; CIP/FactoryTalk not exposed to untrusted networks. **Ext. tools:** `nmap -Pn -p 44818,135 <plc/host>` from the untrusted side (expect filtered); firewall review.	Engineering access from untrusted networks denied; remote via VPN + MFA.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm **FactoryTalk Security** secured actions enforce least privilege for Studio 5000: who may **Go Online / Download / Online Edit / Change Controller Mode / Firmware Update**. A read-only engineer cannot download or change the controller. **Test:** as a low-privilege user, attempt a Download / mode change -> denied and audited. **Ext. tools:** FactoryTalk Admin Console (Logix secured-action matrix); low-privilege negative test.	Least privilege on Download/Edit/Mode/Firmware; negative test confirms denial.	
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 2.3	Use control for portable/mobile devices	Control the engineering laptop and removable media (OS device-control); only authorized .ACD projects and firmware loaded; secure USB. **Ext. tools:** Host removable-media GPO; project/firmware provenance.	Portable/engineering media controlled.	
SR/SAR 2.4	Mobile code	Control mobile/embedded code: restrict any add-ons/AOI content and scripting to trusted, required, signed items; only Rockwell-signed Studio 5000 + AOP installed. **Ext. tools:** Installed AOP/add-on review; verify installer signatures (PCDC).	Only signed/required components/AOIs; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; Studio 5000 relies on the host + FactoryTalk re-auth. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; re-auth required.	Compensating.
SR/CR 2.6	Remote session termination	Confirm online (UMAS-equivalent CIP) sessions can be closed; the controller bounds concurrent programming connections and Studio 5000 reservation prevents conflicting simultaneous edits. **Ext. tools:** Studio 5000 (Who Active / connection review); Wireshark (session).	Sessions terminable; concurrent programming bounded.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Confirm engineering actions are audited: **FactoryTalk Diagnostics** + **AssetCentre** record who downloaded/edited with the FactoryTalk user; the Logix **Controller Log** (5580) records mode/download/firmware events; forward to the SIEM. **Test:** download a change -> AssetCentre + Controller Log entry with user + time. **Ext. tools:** AssetCentre audit; Studio 5000 (Controller Log); SIEM.	Downloads/edits attributable to a FactoryTalk user; controller log captured.	
SR/CR 2.9	Audit storage capacity	Confirm AssetCentre/Controller-Log capacity is sized or offloaded to the SIEM with alerting on collection failure. **Ext. tools:** AssetCentre/SIEM retention + source-silent alert.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the host + controller are NTP-synced so audit/controller-log timestamps are accurate and correlate. **Ext. tools:** `w32tm /query /status`; controller time; Wireshark `ntp`.	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Use **CIP Security** (FactoryTalk Linx) for the controller link so downloads/online edits are authenticated + encrypted; avoid unauthenticated CIP across zone boundaries; contain engineering traffic to the cell. **Ext. tools:** Wireshark (CIP Security vs cleartext CIP); FactoryTalk Policy Manager.	Engineering comms integrity-protected (CIP Security) where supported; contained otherwise.	
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only Rockwell-**signed** Studio 5000 / AOP (verify digital signature / PCDC); host anti-malware with Rockwell-aware exclusions; restrict install/upgrade to admins. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV; installed-version review.	Signed software validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: Security Authority binding, Source Protection, FactoryTalk secured actions, CIP Security, and patch level, against the hardening baseline; compare the .ACD to the archived baseline. **Ext. tools:** Studio 5000 project compare; FactoryTalk review; AssetCentre.	Security settings match the hardening baseline after change.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.4	Software & information integrity	Protect the **.ACD**: **Source Protection** encrypts routines/AOIs; **Security Authority binding** prevents opening/downloading outside the bound directory; enable **Change Detection** (Controller Properties › Security - audit value / change detection) and baseline/version in AssetCentre. **Test:** try to open the protected .ACD on a workstation not in the bound Security Authority -> blocked. **Ext. tools:** Studio 5000 (Source Protection + Security tab); AssetCentre (versioning/change detection); `certutil -hashfile proj.ACD SHA256`.	Source-protected + authority-bound project; change detection on; integrity baselined.	
SR/CR 3.5	Input validation	Patch known Rockwell PSIRT issues (Logix Designer / Studio 5000 parsing/RCE) and confirm the tool/controller handle malformed project/CIP input. **ISOLATED:** test on a lab controller. **Ext. tools:** Nessus/OpenVAS for known CVEs; PSIRT cross-check; ISOLATED CIP fuzz on a bench controller.	Known CVEs patched; no injectable path.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors are handled gracefully without leaking sensitive info (no plaintext secrets in logs / crash dumps). **Ext. tools:** FactoryTalk Diagnostics; host event log review.	Graceful error handling; no info leak.	
SR/CR 3.8	Session integrity	Where CIP Security is applied, online sessions are integrity-protected against replay/hijack; the Security Authority binding protects the project from being opened/altered off-authority. **Ext. tools:** Wireshark (CIP Security session inspection).	Sessions integrity-protected; project bound; replay/tamper prevented.	
SR/CR 3.9	Protection of audit information	Protect the AssetCentre audit store + transport and restrict who can read/clear the controller log (FactoryTalk secured action + host ACLs). **Ext. tools:** AssetCentre access review; controller-log clear permission.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the engineering workstation, remove .ACD projects, Source-Protection keys, certificates, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** grep for secrets; confirm projects/keys removed; BitLocker status.	Projects/keys/certs purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm CIP Security (TLS/DTLS) strong parameters; Source Protection encrypts project source; disable weak/legacy protocols. **Ext. tools:** Wireshark (CIP Security); FactoryTalk Policy Manager.	Modern crypto in use; source encrypted; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the engineering workstation + controllers sit in a segmented cell/OT zone behind a firewall; only required CIP/FactoryTalk flows cross; no flat convergence with IT; remote engineering via a jump host. **Ext. tools:** `nmap -p 44818,2222,135 <plc/host>` per zone; firewall rule review.	Engineering + controllers in a segmented zone; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Engineering software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate projects/controllers and least-privilege FactoryTalk security per area; do not co-mingle unrelated criticality in one project/authority. **Ext. tools:** FactoryTalk area/security segregation; project topology review.	Projects/areas partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm AssetCentre audit + the controller log are readable/exportable by authorized staff and forwarded to the SIEM; passive OT IDS on the cell for CIP anomaly detection. **Ext. tools:** AssetCentre export; Controller Log; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	The engineering tool is not a runtime service, but confirm the host is resourced/hardened and that controller programming connections are bounded so a flood cannot deny engineering access; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; controller connection-limit review.	Host/connection resources bounded; engineering access available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the .ACD projects (source-protected), Source-Protection keys, and FactoryTalk config are backed up (AssetCentre, versioned, offline) and a restore/rebuild is tested. **Ext. tools:** AssetCentre backup; restore + validate on a lab host/controller.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: use FactoryTalk Security (not unsecured projects), apply Security Authority binding + Source Protection, install only required AOP/add-ons, keep Studio 5000 patched, and remove sample projects. **Ext. tools:** Studio 5000/FactoryTalk config review; installed-AOP review; version vs current.	Least functionality; project protection applied; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.8	Component inventory	Inventory Studio 5000 version, installed AOPs/add-ons, and the OS so vulnerabilities track against Rockwell PSIRT / CISA advisories. **Ext. tools:** Studio 5000 About / installed components; Rockwell PSIRT feed.	Accurate version/component inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Studio 5000 Logix Designer	Native project & controller review (all FRs)	Open the .ACD read-only; Controller Properties › Security (Security Authority binding, Change Detection); Tools › Security › Configure Source Protection; Controller Log. Export as the baseline.	Read/authorized project copy.
FactoryTalk Admin Console	Auth/RBAC for Studio 5000 (FR1, 2.1) - see the FactoryTalk sheet	Confirm the Logix secured-action matrix (Download/Edit/Mode/Firmware), users/groups, and password/lockout policy.	Read-only.
FactoryTalk AssetCentre	Audit, versioning & DR (2.8, 3.4, 6.x, 7.3)	Confirm engineering actions are audited, projects versioned/change-detected, and backup/restore available.	Non-intrusive.
ControlFLASH Plus / PCDC + signtool	Signed software & firmware (SAR 3.2, 7.8)	`signtool verify /pa <setup>.exe`; download Studio 5000/AOP/firmware from Rockwell PCDC; verify signatures.	Read-only.
nmap	CIP/service exposure & segmentation (1.13, 3.1, 5.x)	`nmap -sU -p 44818 --script enip-info <plc>`; `nmap -p 44818,2222,135 <host>`; scan per zone.	Read-only; authorized.
Wireshark	CIP Security & session integrity (3.1, 3.8, 4.3)	Filter `enip || cip`; confirm CIP Security (DTLS/TLS) on the controller link vs cleartext CIP.	Passive; SPAN/tap only.
Nessus / OpenVAS + Rockwell PSIRT	CVE scan (3.5, 7.8)	Scan the engineering host for known Studio 5000 / Logix CVEs; cross-check Rockwell PSIRT advisories.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.